

SSLproxy for Deep SSL Inspection

*by
Soner Tari*

Summary

- Inspection
- SSL Inspection
- SSLsplit
- SSLproxy
- Mode of Operation
- Risks of SSL Inspection
- Risks of SSL Inspection - SSL Middlebox Comparison
- Risks of SSL Inspection - SSLproxy
- Conclusion

Inspection

- Unified Threat Management (UTM) services:
 - Virus scan
 - Spam scan
 - Web filtering: Content and url
 - Intrusion detection and prevention
- UTMFW (ComixWall) has been available since 2006: <http://comixwall.org>

SSL Inspection

- Most of the web traffic is now encrypted (HTTPS)
- All e-mail exchange is now encrypted (POP3S, IMAPS, and SMTPS)
- Passive listening does not work even with the private key of the server, due to Perfect Forward Secrecy (PFS)
- Need an active inline SSL/TLS proxy: Man-in-The-Middle (MiTM) proxy
 - Deep SSL inspection, not shallow
 - Hence SSLproxy

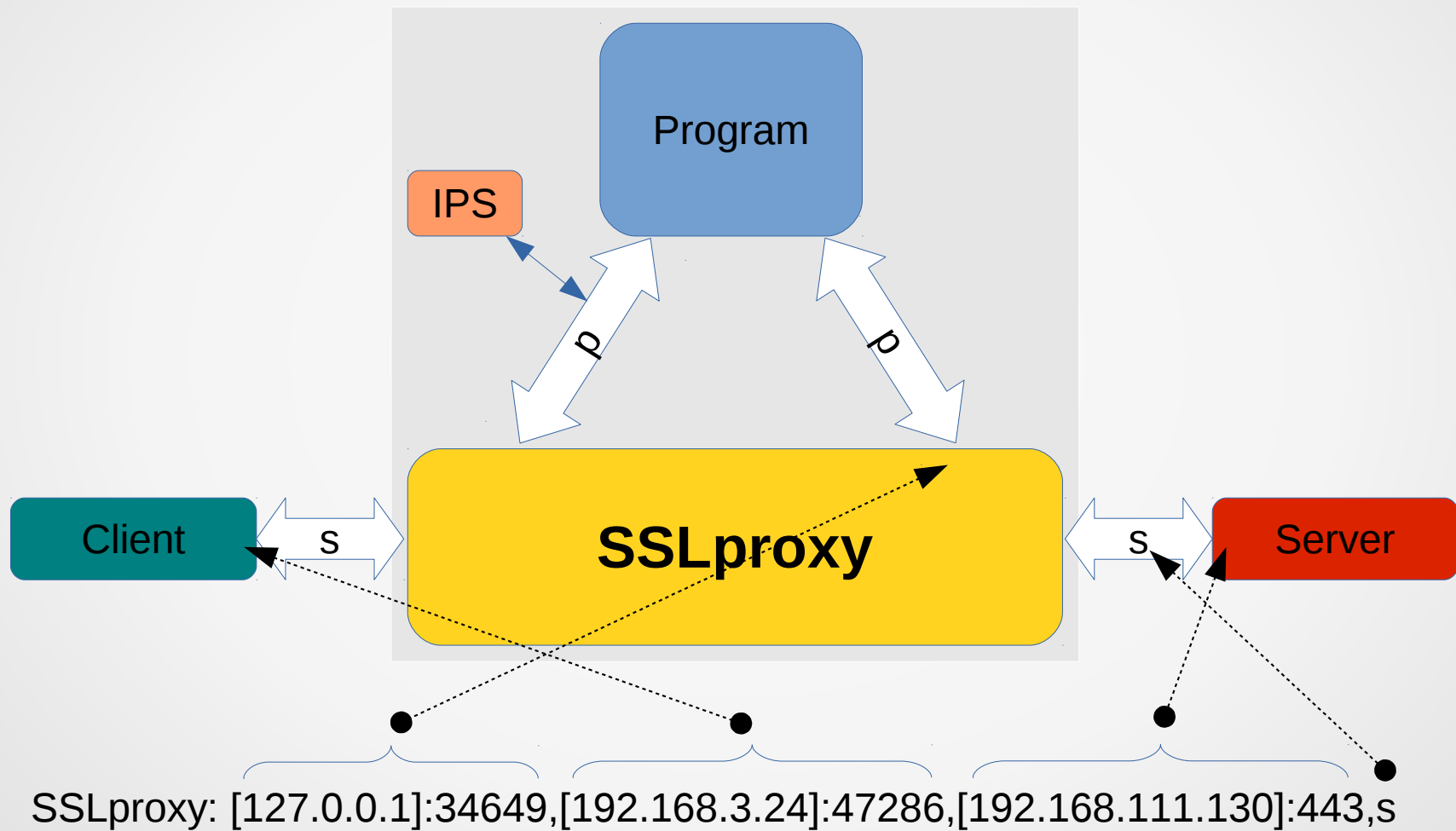
SSLsplit

- MiTM proxy for intercepting SSL/TLS connections
- Can view and record connections:
 - For forensic analysis only (see the risks of ssl inspection)
 - Great if that's all you need
- But does not provide any means to process packets:
 - No scripting support
 - Cannot divert packets to other programs
- Very high quality FOSS code to start with:
 - Event-driven multi-threaded: libevent
 - Privilege separation

SSLproxy

- Intercepts connections, decrypts and diverts packets to other programs (proxy specification)
- The listening program (UTM service) inspects, possibly modifies, and then gives the packets back to SSLproxy
- SSLproxy re-encrypts the packets and sends them to their original destination
- Return packets follow the same path in reverse order
- This requires a special mode of operation, different from SSLsplit:
 - The listening program should be modified to support this mode of operation
- See other differences from SSLsplit:
<https://github.com/sonertari/SSLproxy/issues/1>

Mode of Operation



Mode of Operation

- Similar to divert sockets, but over networking sockets
 - Using networking sockets makes Inline IPS possible
- Inserts an SSLproxy specific line to the first packet:
 - Dynamically assigned IP:port (the address that the SSLproxy expects packets back)
 - Source IP:port (for information purposes)
 - Destination IP:port (for information purposes)
 - Encrypted or plain traffic (for information purposes)
- The listening program should:
 - Parse the SSLproxy line, especially the dynamically assigned address of SSLproxy
 - Return the packets back to the SSLproxy instead of forwarding to their original destination
- Very successful, already in use in UTMFW: Web filter, POP3 & SMTP proxies, IPS
 - See <https://github.com/sonertari/UTMFW>

Risks of SSL Inspection

- Client can only verify the connection between itself and the middlebox:
 - Client not able to verify server's certificate
 - Protocols and ciphers that middlebox negotiates may be invisible to client
- **So clients must rely on the validation performed by the middlebox:**
 - What if the middlebox fails to properly validate the upstream certificate?
 - What if the middlebox uses deprecated protocol versions or weak ciphers?
- For other risks see:
 - The Risks of SSL Inspection,
<https://insights.sei.cmu.edu/cert/2015/03/the-risks-of-ssl-inspection.html>
 - HTTPS Interception Weakens TLS Security,
<https://www.us-cert.gov/ncas/alerts/TA17-075A>

Risks of SSL Inspection - SSL Middlebox Comparison

The Security Impact of HTTPS Interception,

<https://jhalderm.com/pub/papers/interception-ndss17.pdf>

Product	Grade	Validates Certificates	Modern Ciphers	Advertises RC4	TLS Version	Grading Notes
A10 vThunder SSL Insight	F	✓	✓	Yes	1.2	Advertises export ciphers
Blue Coat ProxySG 6642	A*	✓	✓	No	1.2	Mirrors client ciphers
Barracuda 610Vx Web Filter	C	✓	✗	Yes	1.0	Vulnerable to Logjam attack
Checkpoint Threat Prevention	F	✓	✗	Yes	1.0	Allows expired certificates
Cisco IronPort Web Security	F	✓	✓	Yes	1.2	Advertises export ciphers
Forcepoint TRITON AP-WEB Cloud	C	✓	✓	No	1.2	Accepts RC4 ciphers
Fortinet FortiGate 5.4.0	C	✓	✓	No	1.2	Vulnerable to Logjam attack
Juniper SRX Forward SSL Proxy	C	✓	✗	Yes	1.2	Advertises RC4 ciphers
Microsoft Threat Mgmt. Gateway	F	✗	✗	Yes	SSLv2	No certificate validation
Sophos SSL Inspection	C	✓	✓	Yes	1.2	Advertises RC4 ciphers
Untangle NG Firewall	C	✓	✗	Yes	1.2	Advertises RC4 ciphers
WebTitan Gateway	F	✗	✓	Yes	1.2	Broken certificate validation

Fig. 3: **Security of TLS Interception Middleboxes**—We evaluate popular network middleboxes that act as TLS interception proxies. We find that nearly all reduce connection security and five introduce severe vulnerabilities. *Mirrors browser ciphers.

Risks of SSL Inspection - SSLproxy

- SSLproxy:
 - Verifies upstream certificates by default, otherwise terminates the connection immediately
 - Rejects wrong hostnames by default, otherwise terminates the connection immediately
 - Allows enabling or disabling of ciphers
 - Such behavior can be changed in its configuration file
- **So SSLproxy passes all of the tests at <https://badssl.com>, except sha1-intermediate**
- TODO:
 - Disable sha1-intermediate
 - Convey validation of upstream certificate to the client:
 - Use application layer to convey certificate validity?
 - But not everything that accesses data using HTTPS is a human using a web browser

Conclusion

- Except for Blue Coat, SSL inspecting middleboxes pose security risks to clients
- SSLproxy passes all badssl tests except one
- Check source code for any security issues (configuration, privsep server, etc.)
- Learn more about SSL/TLS and security, follow vulnerabilities, related to SSLproxy and UTMFW
- Maintenance (e.g. follow OpenSSL and LibreSSL changes)
- Test performance:
 - Develop a distributed system for very high bandwidth applications? (BTK and wikipedia: HSTS and self-signed BTK certificate)